

Reporte de Seguridad - SolarOps

Fecha: 3 de junio de 2026

Auditado por: Escaneo automatizado de seguridad (Claude Code)

Alcance: Código completo, dependencias, endpoints API, autenticación, almacenamiento de datos

La Version Corta

SolarOps está construido sobre tecnología de punta y segura. Los datos de los clientes están protegidos por múltiples capas de defensa: conexiones encriptadas, autenticación del lado del servidor, políticas de seguridad a nivel de base de datos y gestión adecuada de secretos. La aplicación no es fácilmente hackeable porque un atacante tendría que romper varias barreras de seguridad independientes para llegar a cualquier dato real.

Por Que la Aplicación Es Segura

1. Los datos viajan encriptados

Cada conexión entre el navegador del usuario y los servidores usa HTTPS (encriptación TLS). Vercel, el backend actual de hosting, lo aplica automáticamente. Nadie puede espiar los datos en tránsito. Es como enviar una carta dentro de un tubo de acero cerrado con llave, donde solo la persona al otro lado tiene la llave para abrirlo. End to end key auth.

2. La autenticación la maneja Supabase (una plataforma de nivel industrial)

El inicio de sesión, los tokens de sesión y el cifrado de contraseñas los gestiona Supabase Auth, no código personalizado. Supabase usa bcrypt para cifrar contraseñas, tokens JWT y sigue las mejores prácticas de seguridad usadas por las compañías líderes en aplicaciones en producción.

3. Los secretos del servidor se quedan en el servidor

La llave maestra de Supabase (la que puede saltarse las reglas de seguridad) solo se usa en funciones del lado del servidor. Nunca aparece en el código del navegador. Un atacante que inspeccione el código JavaScript de su navegador (algo que cualquiera puede hacer con cualquier sitio web) no encontrará nada útil. Las llaves están en una habitación cerrada a la que no pueden llegar.

4. Los endpoints API verifican la identidad antes de actuar

Las funciones del servidor (como enviar cotizaciones, notificaciones y consultar datos de SolarEdge) usan un guardia de autenticación compartida (`_auth.ts`) que verifica el token JWT del usuario antes de procesar cualquier solicitud.

5. No se encontraron vulnerabilidades web comunes

- Sin `eval()` ni `dangerouslySetInnerHTML` (las dos formas mas comunes en que los hackers inyectan código malicioso en aplicaciones React)
- Sin vectores de inyección SQL (la librería cliente de Supabase usa consultas parametrizadas)
- Escapado HTML correcto en plantillas de correo electrónico
- El proxy API de SolarEdge valida las rutas URL permitidas para prevenir falsificación de solicitudes del servidor

6. Los archivos de entorno no están en el control de versiones

Todos los archivos `.env` que contienen contraseñas y llaves API están excluidos del repositorio en línea. Solo `.env.example` (con valores de ejemplo) esta incluido.

Por Que Puedes Alojarse Datos de Clientes

Requisito	Como SolarOps lo Cumple
Datos encriptados en transito	HTTPS aplicado por Vercel en cada solicitud
Datos encriptados en reposo	Supabase usa encriptacion AES-256 en la base de datos PostgreSQL
Control de acceso	Supabase Auth con tokens JWT; verificacion de roles del lado del servidor
Gestion de secretos	Llaves API y contraseñas almacenadas como variables de entorno en Vercel, no en el código
Confiabilidad del alojamiento	Vercel (99.99% SLA de disponibilidad) + Supabase (PostgreSQL administrado con respaldos automaticos)
Sin llaves de admin expuestas	La llave de servicio es solo del lado del servidor; el cliente usa la llave anonima restringida

Por Que Esto No Es Fácilmente Hackeable

Para robar datos de clientes, un atacante necesitaría:

1. Romper la encriptación HTTPS (prácticamente imposible con TLS moderno)
2. Obtener un token de sesión de usuario valido (requiere conocer la contraseña del usuario)
3. Evadir las políticas de Row Level Security de Supabase (se aplican a nivel de base de datos, no de aplicacion)
4. Acceder a las variables de entorno del servidor (requiere comprometer la infraestructura de Vercel)

Cada una de estas es una barrera independiente. Romper una no ayuda con las otras. Es como tener que abrir cuatro puertas blindadas, cada una con una llave diferente, en edificios diferentes.

Pero la Parte Mas Importante

La aplicación no es el eslabón débil. Las personas lo son.
Esta es la verdad honesta sobre la seguridad:

La bóveda más fuerte del mundo no importa si alguien le entrega la llave a un desconocido.
SolarOps puede tener encriptación perfecta, código perfecto, reglas de base de datos perfectas. Pero si alguien del equipo:

- Hace clic en un enlace de un correo que dice "Tu contraseña de SolarOps expiro, haz clic aqui para restablecerla" (y es falso)
- Usa la misma contraseña para SolarOps que para su cuenta de Netflix (y Netflix sufre una filtracion)
- Deja su laptop desbloqueada y desatendida.
- Comparte su login con alguien.
- Cae en una llamada telefónica de alguien que se hace pasar por soporte técnico

...entonces ninguna seguridad técnica importa. El hacker no rompió la cerradura. Alguien abrió la puerta y lo invito a pasar.

Esto no es un defecto de SolarOps. Es un defecto de ser humano. Todas las organizaciones del mundo, desde el Pentágono hasta Conexsol, tienen exactamente este mismo problema. Las mayores filtraciones de datos de la historia (Equifax, Target, Colonial Pipeline) comenzaron con un ser humano cometiendo un error, no con un hacker descifrando código.

Lo Que Realmente Protege los Datos de los Clientes

Trabajo de la App (hecho)	Trabajo del Equipo (continuo)
---------------------------	-------------------------------

Encriptar todo en transito	No reutilizar contraseñas
----------------------------	---------------------------

Bloquear la base de datos por usuario	No hacer clic en enlaces de correos sospechosos
---------------------------------------	---

Trabajo de la App (hecho)	Trabajo del Equipo (continuo)
---------------------------	-------------------------------

Mantener secretos en el servidor	No compartir credenciales de acceso
----------------------------------	-------------------------------------

Bloquear entradas maliciosas	Bloquear la laptop cuando se alejen
------------------------------	-------------------------------------

Limitar intentos de abuso	Reportar cualquier cosa que se sienta "rara"
---------------------------	--

La aplicación es una bóveda de acero. Tu equipo es la persona que carga la llave. Si nuestro equipo esta entrenado, y la boveda es irrompible.